

CWE AI Working Group

Meeting Minutes

March 14, 2025

Attendance

- | | | |
|------------------|-------------------|------------------|
| • Monika Akbar | • Scott Drinkall | • Ahmed Nagy |
| • Sven Cattell | • Fernando França | • Kyle Norland |
| • Chris Coffin | • Erick Galinkin | • Raymond Pompon |
| • Steve Christey | • Chris Gourley | • Mike Simon |
| • Coley | • Almir Mesic | • Caroline Rocha |
| • Marissa Dotter | • Dave Morse | • Alec Summers |

Agenda:

- Meeting Introduction
- Status Updates
- Detailed Discussion: CWE-1039 (Adversarial Perturbations)
- Work Planning

Meeting Notes:

Meeting Introduction: Alec introduced the March 14 meeting of the AI Working Group. Steve outlined the agenda, which included status updates for the CWE AI WG, a discussion on an older CWE about adversarial perturbations, and future work priorities.

Introduction of New Members: Two new subgroup members introduced themselves: Marissa from MITRE and Fernando from Critical Software, who shared their backgrounds and reasons for joining the group.

Modifications to CWE-1039 (Marissa Dotter)

- **Introduction:** Steve framed the discussion, noting the initial focus on image recognition, the absence of real changes since the CWE's creation, and that it is an incomplete entry. Marissa is joining the team to help make focused improvements to the CWE-1039. CWE 4.17 is expected to be released April 3, 2025.
- **Adversarial Perturbation CWE Update:** Marissa presented her work on updating CWE-1039, focusing on adversarial input perturbations. She discussed changes to

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

the title, description, common consequences, modes of introduction, and mitigations.

- **Title Changes:** Marissa discussed potential changes to the title of CWE-1039 to make it more concise and focused on the weakness rather than the application. She suggested rephrasing it to highlight inadequate detection and handling of adversarial input perturbations in AI systems. The group discussed dropping *detecting* as a sub-process of *handling*. Steve noted that handling and detecting are distinct categories. The group also discussed whether the nomenclature *adversarial input perturbations* is too specific.
- **Description Updates:** Marissa proposed minor edits to the extended description.
 - The group discussed the phrasing *automated mechanism*, recognizing there are still more traditional approaches being used. Steve noted that manual methodologies are also commonly used in CWEs.
 - Marissa proposed adding the phrasing *or has not adequately undergone test and evaluation* to highlight the need for T&E of the system and a targeted technologies example to include *automated malware detection*. Erick asked whether detection bypasses are considered a weakness in a CWE perspective. Steve provided context for the argument against putting malware evasion into CVE and suggested a disclaimer so that every bypass is not labeled as a weakness.
- **Common Consequences:** Marissa suggested adding common consequences and modes of introduction for CWE-1039, including disruption of services, privacy leakage, and lack of verification and testing.
 - Marissa highlighted that adversarial input perturbations could lead to service disruption or failure, emphasizing the importance of robust detection and handling mechanisms in AI systems.
 - She added that these perturbations could result in privacy leakage, particularly through membership inference attacks, which could expose sensitive data or model information.
- **Modes of Introduction:** Marissa noted the need for thorough verification, testing, and evaluation of AI systems to ensure they can handle adversarial inputs effectively, reducing the risk of weaknesses being introduced during deployment.
- **Potential Mitigations:** Marissa discussed potential mitigations, such as model pruning and compressing, input sanitization and transformations, and

defensive distillation, to address adversarial input perturbations. She also mentioned the need for more detection examples to enhance the CWE entry.

- **Future Work Planning:** Steve discussed future work planning, including updating specific elements of CWEs, finding AI-specific examples, and considering other CWEs that may be relevant to AI and machine learning components.
 - **Updating CWE Elements:** Steve emphasized the importance of updating specific elements of CWEs, such as observed examples, references, and mitigations, to ensure they are relevant to AI and machine learning components.
 - **AI-Oriented Examples:** Steve highlighted the need to find AI-specific examples to enhance the understanding and applicability of CWEs in the context of AI systems, noting the challenges in identifying real-world examples.
 - **Relevant CWEs:** Steve suggested considering other CWEs that may be increasingly relevant to AI and machine learning, such as hidden functionality, to ensure comprehensive coverage of potential weaknesses.
 - **Systematic Review:** Steve proposed conducting systematic reviews of AI-related documents, such as the OWASP Top 10 for LLMs and NIST documents, to identify and map relevant weaknesses to CWEs. This would be a way to relate the CWE work to other AI-oriented work.
- **Collaboration Methods:** Steve proposed various methods for collaboration on modifications, including using the AIWG mailing list, focused discussion in CDR, and editing shared documents like Google Docs.

Action Items:

- **CWE 1039 Updates:** Share the updated document for CWE 1039 with the working group for review and feedback. (Marissa)
- **Google Docs Collaboration:** Set up a Google Docs document for collaborative editing and review of modifications for CWE-1039 and CWE-912. (Steve)